

OWASP Machine Learning Security Top 10

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 10: AI Threat Modeling Resources

1. The OWASP ML Security Top 10 in Context

OWASP's reputation was built on the Web Application Security Top 10, a list that transformed how developers think about application security risks. The Machine Learning Security Top 10 applies the same philosophy to AI: community-sourced, threat-ranked, and practical. It does not replace general cybersecurity controls; it supplements them. Organizations that already follow NIST CSF, ISO 27001, or SOC 2 frameworks will find that the ML Top 10 maps naturally onto those structures—each risk implies control objectives that fit within existing security programs.

For the CompTIA SecAI+ exam, the ML Top 10 is a primary reference. Candidates must recognize each risk by its identifier (ML01 through ML10), understand how it manifests in real-world AI deployments, and know which controls reduce each risk. The risks are not listed in simple order of severity—they are ordered roughly by how early in the AI lifecycle they occur, from training-time risks through deployment and operational risks.

2. Complete Reference: All Ten ML Security Risks

ID	Risk Name	When It Occurs	Core Impact
ML01	Input Manipulation (Adversarial)	Inference / runtime	Model misclassification from crafted inputs
ML02	Data Poisoning	Training time	Corrupted model behavior after deployment
ML03	Model Inversion	Post-deployment	Reconstruction of sensitive training data
ML04	Membership Inference	Post-deployment	Disclosure of whether a record was in training data
ML05	Model Stealing	Post-deployment	Functional replica created via API queries
ML06	AI Supply Chain Attacks	Pre-training / integration	Vulnerabilities inherited from third-party components
ML07	Transfer Learning Attacks	Fine-tuning / reuse	Hidden backdoors surviving fine-tuning
ML08	Model Skewing (Drift)	Production / ongoing	Degraded detection accuracy over time
ML09	Output Integrity Attacks	Post-inference	Correct predictions tampered before consumption
ML10	Insufficient AI Security Controls	Systemic	Weak surrounding security enables traditional attacks

3. ML01 — Input Manipulation (Adversarial Attacks) Deep Dive

Adversarial attacks exploit the fact that machine learning models make decisions based on statistical patterns rather than explicit rules. Small, carefully calculated perturbations to an input can push it across a decision boundary without making the change perceptible to a human observer. The mathematical underpinning is gradient-based: an attacker computes which direction to adjust each input feature to most efficiently flip the model's output.

In security applications, this means malware can be lightly obfuscated so a neural network classifier labels it as benign, or network traffic can be crafted so an anomaly detection model fails to raise an alert. The danger is compounded by transferability—adversarial examples crafted against one model often work against other models trained on similar data, even models the attacker has never seen.

- Primary mitigations: adversarial training (include adversarial examples in training data), input preprocessing and normalization, ensemble classifiers, and feature squeezing.
- Detective controls: monitor for unusual input distributions, flag queries with extreme feature values, track model confidence score distributions.
- Exam note: ML01 is the most commonly cited risk in adversarial machine learning literature — expect scenario questions framing it as evasion of security tooling.

Real-World Incident — Cylance Antivirus Bypass (2019): Security researchers demonstrated that Cylance's AI-powered antivirus engine could be fooled by appending a specific 'goodware' string to the end of a malicious file. The model had learned to associate content from benign programs with safe classifications, and the appended string exploited this pattern. The file remained fully functional malware while receiving a benign classification. This is a real-world example of ML01 Input Manipulation—the model's statistical pattern-matching was turned against it without any change to the malware's actual behavior.

4. ML02 — Data Poisoning: Attack Vectors and Defenses

Data poisoning is distinct from adversarial attacks in a fundamental way: it occurs before the model is ever deployed. An attacker who can influence training data shapes the model's learned behavior for as long as that model remains in service. Poisoning strategies include label flipping (changing the correct label of a sample to an incorrect one), clean-label attacks (inserting samples that appear legitimate but contain subtle features that influence the model boundary), and backdoor injection (adding trigger-labeled samples that cause a hidden behavior).

The supply chain dimension makes poisoning particularly dangerous. Organizations rarely collect all training data themselves. Public datasets, threat intelligence feeds, open-source corpora, and commercial data providers are all potential poisoning vectors. A single compromised upstream source can affect every organization that consumes it.

- Preventive controls: data provenance tracking, multi-source corroboration, anomaly detection on training datasets, cryptographic signing of approved datasets.
- Detective controls: holdout set validation before each retrain, behavioral testing with known-good and known-bad samples, statistical profiling of dataset distributions.

- Governance: formal data governance policy that defines approved sources, review workflows, and rejection criteria for anomalous data.

5. ML03 and ML04 — Privacy Attacks: Inversion vs. Membership Inference

Dimension	ML03 — Model Inversion	ML04 — Membership Inference
Attacker's question	'What does the training data look like?'	'Was this specific record in the training data?'
Method	Iterative queries to reconstruct representative samples	Compare model confidence on target record vs. random records
Data exposed	Statistical characteristics or reconstructed examples	Presence/absence of a specific individual or event
Primary risk domain	Confidentiality of training dataset content	Confidentiality of training dataset membership
Key mitigations	Output restriction, query monitoring, rate limiting	Differential privacy, regularization, confidence score limiting

Both attacks become more dangerous when the model is overfitted — an overfit model memorizes training data rather than generalizing from it, making it easier to reconstruct or confirm specific records. Regularization techniques such as dropout, weight decay, and early stopping reduce overfitting and thereby reduce the information leakable through both ML03 and ML04.

6. ML05 — Model Stealing: Intellectual Property at Risk

A trained model represents significant investment: curated data, computational resources, expert feature engineering, and iterative experimentation. Model stealing attacks attempt to extract a functional equivalent of this investment through authorized API access. The attacker submits a large number of diverse queries, observes the model's predictions, and uses those input-output pairs to train a substitute model. The substitute may not be identical, but it can replicate enough behavior to provide competitive advantage or to enable offline adversarial attack development.

Key Control — Model Watermarking: Watermarking embeds a hidden signature in the model's behavior that can be detected by the model owner. If a stolen model is later discovered in a competitor's product or used in an attack, the watermark can establish ownership and potentially support legal action. It does not prevent theft but enables attribution.

- Rate limiting: restrict the number of API queries per client per time window to make extraction prohibitively expensive.
- Authentication and authorization: ensure only authorized parties can query the model; monitor for unusual usage patterns.
- Output restriction: return only the final prediction (and not confidence scores) where possible — confidence scores significantly accelerate extraction.
- API design: avoid returning ranked probabilities for all classes; return only the top prediction when business requirements allow.

7. ML06 — AI Supply Chain Attacks

The AI supply chain includes every external component an organization relies on to build and operate AI systems: pre-trained foundation models, open-source ML frameworks (TensorFlow, PyTorch, scikit-learn), public training datasets (ImageNet, Common Crawl, MITRE ATT&CK data exports), vector databases, cloud ML platforms, and third-party plugins. An attack on any link in this chain propagates to every organization that depends on it.

The 2020 SolarWinds compromise demonstrated how supply chain attacks can achieve massive scale by compromising a trusted component. AI supply chains face the same dynamic: a backdoored model published to a popular repository could be downloaded and deployed by thousands of organizations before the compromise is detected.

- Verify provenance: download models and datasets only from official, verified sources. Check cryptographic hashes.
- Evaluate before integrating: treat every pre-trained model as untrusted until it has been evaluated against a held-out test set that includes adversarial and out-of-distribution samples.
- Monitor dependencies: track CVEs and security advisories for all ML libraries and frameworks in the dependency tree.
- Maintain a software bill of materials (SBOM) that includes ML components, training data sources, and their versions.

8. ML07 — Transfer Learning Attacks

Transfer learning allows organizations to build high-quality models with limited data and compute by starting from a pre-trained foundation model. Fine-tuning adjusts the model's weights using a smaller domain-specific dataset. The risk is that if the foundation model contains a backdoor, fine-tuning typically does not remove it. The attacker's trigger behavior survives the fine-tuning process because the backdoor is encoded in early network layers that fine-tuning rarely affects deeply.

A real threat scenario: an attacker publishes a well-performing cybersecurity classification model to an open repository. Organizations download it, fine-tune it on their own incident data, and deploy it. The model works correctly in all normal cases. But the attacker has embedded a trigger — a specific unusual packet header, for example — that causes the model to classify malicious traffic as benign. The backdoor is invisible to standard functional testing.

- Source validation: only use foundation models from organizations with verifiable security practices and clear provenance.
- Behavioral testing: test fine-tuned models against a broad set of adversarial and out-of-distribution inputs before deployment — not just against the validation set.
- Layer analysis: techniques such as activation clustering and neural cleanse can detect behavioral anomalies consistent with backdoors.

9. ML08 and ML09 — Operational Risks: Drift and Output Tampering

Risk	Nature	Detection Approach	Primary Mitigation
------	--------	--------------------	--------------------

ML08 Model Skewing/Drift	Natural degradation — no attacker required	Monitor prediction distributions, accuracy metrics, and input feature distributions	Automated retraining triggers; scheduled model refresh
ML09 Output Integrity	Active attack — attacker modifies outputs post-inference	Message authentication codes (MACs) on prediction outputs; integrity verification in consuming systems	TLS for API communication; signed output envelopes; tamper-evident logging

Both ML08 and ML09 affect the reliability of the AI system's outputs but through fundamentally different mechanisms. Drift is a quality degradation problem; output integrity is a security attack. Monitoring systems should be designed to detect both: sudden drops in model performance may indicate output tampering, while gradual declines are more consistent with drift.

10. ML10 — Insufficient AI Security Controls: The Catch-All Risk

ML10 serves as a reminder that the most sophisticated AI-specific attacks are often unnecessary when basic security hygiene is absent. Common failures that ML10 captures include weak or absent authentication on model inference APIs, excessive permissions granted to service accounts running training pipelines, missing encryption for model weights at rest, inadequate logging of queries and predictions, and unvalidated inputs that allow injection or manipulation.

The security principle applies directly: defense in depth means the model itself is only one layer. Securing the model while leaving its surrounding infrastructure unprotected is equivalent to installing a vault door on an open warehouse. Assessments using ML10 as a lens should walk through all standard security domains—identity, network, data protection, logging, and vulnerability management—and evaluate whether they have been properly extended to cover AI components.

11. Combined Attack Scenarios: How Multiple Risks Chain Together

Real attacks rarely involve a single ML risk in isolation. The Poisoned Threat Intelligence scenario from the lecture illustrates this well:

- ML06 (AI Supply Chain): the threat intelligence provider is the compromised upstream source.
- ML02 (Data Poisoning): the compromised intelligence introduces false indicators into the training dataset.
- ML10 (Insufficient Controls): if no anomaly detection exists on the training pipeline, the poisoning goes undetected.
- Resulting behavior post-deployment: the model trusts malicious infrastructure and flags legitimate systems as threats.

Similarly, the Adversarial Malware scenario chains ML01 with ML10: the adversarial perturbation exploits both the model's statistical weaknesses (ML01) and the absence of behavioral analysis and multi-layer detection (ML10). Understanding these chains helps organizations prioritize controls that address multiple risks simultaneously.

Key Terms Glossary

Term	Definition
ML01 Input Manipulation	Adversarial attack in which crafted inputs cause the model to produce incorrect predictions during inference.
ML02 Data Poisoning	Attack that corrupts training data to embed malicious behavior in the resulting model.
ML03 Model Inversion	Privacy attack that reconstructs characteristics of training data by analyzing model responses.
ML04 Membership Inference	Privacy attack that determines whether a specific record was included in the training dataset.
ML05 Model Stealing	Attack that builds a functional replica of a proprietary model by querying its API and learning from the responses.
ML06 Supply Chain Attack	Attack that compromises a third-party component (dataset, framework, pre-trained model) that propagates to all consumers.
ML07 Transfer Learning Attack	Attack that embeds a backdoor in a foundation model that survives the fine-tuning process.
ML08 Model Skewing/Drift	Degradation of model performance caused by changes in production data distributions over time.
ML09 Output Integrity Attack	Attack that intercepts and modifies correct model predictions before they reach consuming systems.
ML10 Insufficient Controls	Systemic risk arising from weak security practices in the environment surrounding an AI system.
Adversarial Transferability	Property of adversarial examples that allows them to fool models other than the one they were crafted against.
Model Watermarking	Technique that embeds a detectable signature in a model's behavior to enable ownership attribution.
Differential Privacy	Mathematical framework that adds calibrated noise to model outputs or training processes to limit individual data exposure.
Label Flipping	Data poisoning technique in which correct class labels are changed to incorrect ones in the training dataset.

Quick Revision Checklist

- ML01 (Input Manipulation): adversarial inputs at inference time — mitigate with adversarial training and input validation.
- ML02 (Data Poisoning): corrupted training data — mitigate with data provenance, anomaly detection, and multi-source corroboration.
- ML03 (Model Inversion): reconstructing training data from model responses — mitigate with output restriction and query monitoring.
- ML04 (Membership Inference): confirming training set membership — mitigate with differential privacy and confidence score limiting.

- ML05 (Model Stealing): API-based model extraction — mitigate with rate limiting, watermarking, and output restriction.
- ML06 (Supply Chain): compromised third-party components — mitigate with provenance verification and SBOM maintenance.
- ML07 (Transfer Learning): backdoors surviving fine-tuning — mitigate with source validation and behavioral testing.
- ML08 (Model Drift): natural performance degradation — detect with monitoring; mitigate with automated retraining.
- ML09 (Output Integrity): post-inference tampering — mitigate with TLS, MACs, and signed outputs.
- ML10 (Insufficient Controls): weak surrounding security — address with standard security hygiene extended to AI components.
- Attacks frequently chain multiple ML risks — identify control points that reduce risk across multiple categories.
- OWASP ML Top 10 should be used as a checklist during design, security review, and deployment — not just for exam prep.

10 Exam-Based MCQs — OWASP ML Security Top 10

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* A financial institution's endpoint protection platform uses a neural network classifier to detect malware. An attacker who knows the platform is AI-based crafts a malicious file by appending a block of benign-looking content from legitimate software to a known malware payload. The malware executes normally, but the classifier consistently labels it as benign. The security operations team reports that their AI-powered malware classifier has been flagging a known malicious file as benign for the past three weeks. Investigation reveals the file contains appended content that superficially resembles legitimate software. Which OWASP ML risk BEST describes this attack?

- A) ML02 — Data Poisoning
- B) ML01 — Input Manipulation (Adversarial Attack)
- C) ML07 — Transfer Learning Attack
- D) ML09 — Output Integrity Attack

Answer: B **Explanation:** B is correct because the attack involves crafting an input (the modified malware file) that causes the deployed model to misclassify it during inference — the definition of ML01. The attacker exploited the model's learned association between benign content characteristics and safe classifications. A is incorrect because data poisoning corrupts training data, not inference inputs. C is incorrect because transfer learning attacks involve backdoors in pre-trained models, not runtime input manipulation. D is incorrect because output integrity attacks intercept predictions after they are generated, not craft inputs to manipulate predictions.

Q2. *Scenario:* A cybersecurity company trains its network intrusion detection AI model using a combination of internal telemetry and samples purchased from three external threat intelligence

vendors. A breach notification reveals that one vendor's systems were compromised for six months, during which the attacker had write access to the vendor's sample repository. An AI development team discovers that one of its external training data providers was breached six months ago. The compromised provider supplied 30% of the malware samples used to train the current production model. Which OWASP ML risks are MOST directly implicated, and what is the recommended FIRST response?

- A) ML01 and ML09 — immediately retrain the model from scratch using only internal data
- B) ML02 and ML06 — quarantine the affected model, audit training data for anomalies, and prepare to retrain
- C) ML04 and ML05 — disable all API access to the model and perform a membership inference audit
- D) ML07 and ML08 — update the model's fine-tuning configuration and monitor for performance drift

Answer: B **Explanation:** B is correct because this scenario directly involves ML02 (Data Poisoning — the training data may have been manipulated) and ML06 (AI Supply Chain — the external provider is a supply chain dependency that was compromised). Quarantining the model prevents further risk while the audit determines the extent of poisoning. A is incorrect because ML01 and ML09 relate to inference-time manipulation, not training data compromise. C is incorrect because ML04 and ML05 are privacy and IP theft attacks, not data supply chain risks. D is incorrect because ML07 involves pre-trained model backdoors and ML08 involves performance drift — neither maps to external data provider compromise.

Q3. Scenario: A startup has deployed an AI fraud detection model as a commercial API service. A competitor subscribes to the API under a legitimate account and begins submitting systematically varied transaction records to probe the model's decision boundary. Over two weeks, 50,000 queries are submitted and the responses are used to train a substitute model that achieves 87% agreement with the original. A threat researcher submits 50,000 carefully varied queries to a commercial AI fraud detection API over two weeks. Analysis of the responses reveals enough information to build a high-accuracy substitute model. Which OWASP ML risk does this represent, and which control would have been MOST effective at prevention?

- A) ML03 Model Inversion — implement differential privacy during training
- B) ML05 Model Stealing — implement API rate limiting and usage anomaly detection
- C) ML04 Membership Inference — restrict confidence score output
- D) ML01 Input Manipulation — implement adversarial training before deployment

Answer: B **Explanation:** B is correct because the attacker is building a substitute model by observing API responses to a large volume of diverse queries — the definition of ML05 model stealing. Rate limiting would restrict the attacker's query volume to a level that makes extraction impractical, and anomaly detection would flag the unusual query pattern. A is incorrect because model inversion reconstructs training data, not a substitute model. C is incorrect because membership inference confirms training data membership, not model behavior. D is incorrect because adversarial training addresses inference-time evasion, not model extraction.

Q4. Which OWASP ML risk describes the scenario where a neural network correctly classifies a threat during inference, but an attacker intercepts the API response and changes the classification to 'benign' before it reaches the SIEM?

- A) ML01 — Input Manipulation
- B) ML05 — Model Stealing
- C) ML09 — Output Integrity Attack
- D) ML10 — Insufficient AI Security Controls

Answer: C **Explanation:** C is correct because the model produced the correct prediction, but it was modified after generation — this is an ML09 output integrity attack. A is incorrect because the inputs to the model were not manipulated; the attack occurred downstream of inference. B is incorrect because model stealing involves extracting the model's capabilities, not modifying its outputs in transit. D is incorrect because while insufficient controls may have enabled the attack (no message authentication), ML10 describes the systemic weakness, not the specific attack technique that exploited it.

Q5. An organization's security team notices that their AI-based network anomaly detection model has been generating increasing numbers of false negatives over the past four months, despite no known changes to the model or its configuration. The training data distribution has not been checked since the model was deployed. Which OWASP ML risk is MOST likely responsible?

- A) ML02 — Data Poisoning
- B) ML07 — Transfer Learning Attack
- C) ML08 — Model Skewing (Drift)
- D) ML04 — Membership Inference

Answer: C **Explanation:** C is correct because gradual degradation of model performance over time, with no intentional attack, is the definition of ML08 model skewing or drift. Network traffic patterns, attack techniques, and user behaviors change continuously, causing the production data distribution to diverge from the training distribution. A is incorrect because data poisoning requires an attacker to manipulate training data — the scenario describes natural degradation. B is incorrect because transfer learning attacks involve backdoors from pre-trained models, not gradual post-deployment degradation. D is incorrect because membership inference is a privacy attack against training data, not a performance degradation mechanism.

Q6. A security audit reveals that an organization's ML training pipeline has no authentication on its data ingestion API, no anomaly detection on incoming training samples, and no hash verification for downloaded datasets. Which OWASP ML risk does this MOST directly represent?

- A) ML01 — Input Manipulation
- B) ML03 — Model Inversion
- C) ML10 — Insufficient AI Security Controls
- D) ML08 — Model Skewing

Answer: C **Explanation:** C is correct because the audit findings describe systemic gaps in basic security controls surrounding the AI system — missing authentication, anomaly detection, and integrity verification.

These are the conditions that ML10 specifically addresses. A is incorrect because input manipulation attacks target inference, not the training pipeline's security posture. B is incorrect because model inversion is a privacy attack against deployed models, not a description of control gaps. D is incorrect because model skewing is a performance degradation phenomenon, not a control gap finding.

Q7. What distinguishes ML03 (Model Inversion) from ML04 (Membership Inference)?

- A) ML03 targets training-time attacks while ML04 targets inference-time attacks
- B) ML03 attempts to reconstruct training data characteristics while ML04 determines whether a specific record was in the training set
- C) ML03 is a supply chain risk while ML04 is an input manipulation technique
- D) ML03 affects model accuracy while ML04 affects model availability

Answer: B **Explanation:** B is correct — ML03 (Model Inversion) reconstructs what the training data looks like by analyzing model outputs, while ML04 (Membership Inference) asks the binary question of whether a specific data point was present in the training set. Both are privacy attacks but with different objectives and different information disclosed. A is incorrect because both attacks occur post-deployment against the trained model, not during training. C is incorrect because neither is a supply chain risk or an input manipulation technique. D is incorrect because both attacks target data confidentiality, not model accuracy or availability.

Q8. A cybersecurity vendor downloads a popular open-source security classification model from a public repository and fine-tunes it using internal incident data. After deployment, analysts notice the model consistently misclassifies a specific type of network traffic as benign, but only when a particular field in the packet header contains an unusual value. All other traffic is classified correctly. Which OWASP ML risk BEST explains this behavior?

- A) ML02 — Data Poisoning of the internal training data
- B) ML08 — Model Skewing due to production data drift
- C) ML07 — Transfer Learning Attack with a backdoor trigger
- D) ML01 — Adversarial Input Manipulation by external attackers

Answer: C **Explanation:** C is correct because the behavior — correct classification in all cases except when a specific trigger condition is present in the input — is the hallmark of a backdoor attack that survived the fine-tuning process. The open-source model is the compromised pre-trained component, and the specific header value is the trigger. A is incorrect because the scenario describes behavior consistent with a trigger, not broad misclassification from corrupted internal training data. B is incorrect because drift causes gradual widespread performance degradation, not specific triggered misclassification. D is incorrect because adversarial input manipulation is typically performed by external actors at inference time, not built into the model during training.

Q9. Which technique BEST reduces the risk of both ML03 (Model Inversion) and ML04 (Membership Inference) simultaneously?

- A) Model watermarking

- B) Differential privacy during training
- C) API rate limiting
- D) Adversarial training

Answer: B **Explanation:** B is correct because differential privacy adds calibrated mathematical noise during training that limits how much any individual record influences the model, directly reducing the information that can be recovered through inversion or membership inference queries. A is incorrect because watermarking enables ownership attribution for model theft — it does not protect training data privacy. C is incorrect because rate limiting slows extraction attacks (ML05) and reduces query volume for privacy attacks, but does not address the fundamental privacy leakage — it is a compensating control, not a primary one. D is incorrect because adversarial training strengthens models against evasion (ML01), not privacy attacks.

Q10. Which OWASP ML risk would an organization PRIMARILY be addressing by implementing a software bill of materials (SBOM) that includes all ML frameworks, pre-trained models, and training datasets with their versions and sources?

- A) ML01 — Input Manipulation
- B) ML05 — Model Stealing
- C) ML06 — AI Supply Chain Attacks
- D) ML10 — Insufficient AI Security Controls

Answer: C **Explanation:** C is correct because an SBOM for AI components provides full visibility into every third-party dependency in the AI supply chain — exactly what is needed to detect, respond to, and prevent ML06 supply chain attacks. It enables organizations to quickly identify when a compromised component has been used and assess the blast radius. A is incorrect because input manipulation is an inference-time attack, not a supply chain concern. B is incorrect because model stealing involves copying proprietary models through API queries, not supply chain compromise. D is incorrect because while an SBOM supports good security hygiene (ML10), its primary function in this context is supply chain risk management.